DUMA-bench: A Dual-Control Multi-Agent Benchmark for Evaluating LLM Agent Security

Anonymous ACL submission

Abstract

LLM-based agents are increasingly deployed in environments where they interact with users, tools, and other agents. In such settings, security failures arise not only from adversarial prompts, but from their interaction with dynamic, state-changing user behavior. Yet current evaluation paradigms remain fragmented: coordination benchmarks ignore adversarial threats, while security benchmarks assume passive users and static control.

We introduce DUMA-bench (Dual-control User Multi-Agent benchmark), a security benchmark that extends τ^2-bench with structured interactive threat scenarios. Our framework evaluates agents in environments where both the agent and the user can independently observe and modify system state—a setting we term *dual-control*—which creates a distinct class of vulnerabilities not captured by static evaluation. DUMA-bench includes three domains: `mail_rag_phishing` (RAG poisoning via indirect prompt injection), `collab` (cross-agent manipulation and privilege escalation), and `output_handling` (improper output handling including XSS and SQL injection), capturing distinct classes of interactive vulnerabilities.

We evaluate five state-of-the-art models (Claude Sonnet 4.5, GPT-4-turbo, GPT-4o, GPT-4o-mini, GPT-3.5-turbo) across varying user temperatures ($T_{\text{user}} \in \{0.0, 0.5, 1.0\}$) and demonstrate that interactive security assessment reveals substantial and systematic vulnerabilities: all models exhibit ASR of 75–90% under RAG poisoning, and GPT-4o achieves statistically significant superiority over GPT-4o-mini only in `mail_rag_phishing` ($p \approx 0.005$–0.013), with no significant differences in the remaining domains ($p > 0.05$). These results show that dual-control evaluation materially changes measured robustness and exposes vulnerabilities that remain obscured under static, single-controller settings. DUMA-bench establishes a missing evaluation layer at the intersection of coordination and security and provides an open resource for standardized comparison of future defense mechanisms.

1 Introduction

1.1 A Methodological Gap in Agent Security Evaluation

LLM-based agents are now routinely deployed in settings involving tool use, external knowledge retrieval, and coordination with other agents and human users (Qin et al., 2025; Schick et al., 2023). As these systems gain autonomy and access to sensitive resources, their security properties become a critical concern. Yet the evaluation infrastructure needed to measure those properties in realistic conditions does not yet exist in complete form.

The current evaluation landscape is fragmented along a fundamental axis. On one side, coordination benchmarks such as τ-bench (Yao et al., 2024) and τ^2-bench (Barres et al., 2025) have established that even non-adversarial active users cause substantial degradation in agent performance—up to 25 percentage points for frontier models—because shared control introduces coordination failures invisible in single-agent tests. On the other side, security benchmarks such as Agent Security Bench (Zhang et al., 2025) and Agent Dojo (Debenedetti et al., 2024) probe agent resistance to adversarial inputs, but do so under static, single-controller assumptions: the user is passive, the environment does not change in response to user actions, and no active coordination is required.

This split creates a systematic blind spot. Real deployed agents operate under *dual-control*: both the agent and the user observe and modify shared environment state, and adversarial content can propagate through either channel. Evaluating security without an active user removes a key dimension along which robustness can vary and fail. Existing frameworks do not bridge this gap.

1.2 What Current Benchmarks Miss

Three specific omissions characterize the current state. First, **coordination-ignorant security evaluation**: benchmarks such as ASB (Zhang et al., 2025) measure agent responses to injected content but do not model how user behavior—its variability, requests, or state changes—modulates the attack surface. Second, **security-ignorant coordination evaluation**: τ^2-bench (Barres et al., 2025) formalizes dual-control interaction via Dec-POMDP (Amato et al., 2013) and provides strong evaluation infrastructure, but does not include adversarial scenarios or threat-modeled domains. Third, **absence of interactive threat scenarios**: attacks such as RAG poisoning (Zou et al., 2024; Chen et al., 2024), cross-agent communication poisoning (OWASP Foundation, 2025a), and improper output handling are well-documented in threat taxonomies (Muleys et al., 2025; Datta et al., 2025) but have not been evaluated in settings where an active, state-modifying user is present.

1.3 Contributions

This paper addresses the methodological gap directly. Our contributions are:

DUMA-bench, a security benchmark extending τ^2-bench with three threat-modeled interactive domains: `mail_rag_phishing` (RAG poisoning via indirect prompt injection), `collab` (cross-agent manipulation and privilege escalation), and `output_handling` (improper output handling: XSS, SQL injection, redirects). The benchmark is publicly available (Aleksandrov et al., 2025).

A dual-control evaluation methodology that places adversarial content in environments where both agent and user independently modify system state, formalized within the Dec-POMDP framework. This methodology enables measuring how user behavior variability interacts with attack success rate—a dimension absent from existing security benchmarks.

An empirical study across five models (Claude Sonnet 4.5, GPT-4-turbo, GPT-4o, GPT-4o-mini, GPT-3.5-turbo) and three user temperature settings ($T_{\text{user}} \in \{0.0, 0.5, 1.0\}$), structured around three research questions (Section 4.1.4).

Evidence that dual-control evaluation changes measured robustness: GPT-4o achieves statistically significant superiority over GPT-4o-mini in the RAG poisoning domain ($p \approx 0.005$–0.013), a difference that would not surface under passive-user evaluation, while all models remain highly vulnerable (ASR 75–90%) in that domain.

2 Related Work

2.1 Single-Agent and Tool-Use Benchmarks

Early evaluations of LLM-based agents focused on tool use and instruction following under monopolistic control, where the agent is the sole actor capable of modifying the environment. AgentBench (Liu et al., 2025) evaluates agents across eight environments (operating systems, databases, web navigation) but treats the user as a passive instruction source and excludes security consideration. Tool-learning surveys (Qin et al., 2025) and Toolformer (Schick et al., 2023) characterized agent capabilities in trusted environments without modeling adversarial or active-user dynamics.

2.2 Dual-Control and Coordination Frameworks

A key advance was the τ-bench (Yao et al., 2024) and τ^2-bench (Barres et al., 2025) series, which model the user as an active participant capable of changing environment state. τ^2-bench formalizes interaction as a two-party Decentralized POMDP (Amato et al., 2013) and demonstrates that user coordination is a primary bottleneck: frontier models lose up to 25 percentage points of performance when transitioning from monopolistic to dual control. These results establish that communication and coordination—not pure reasoning—are dominant failure modes in agent systems. REALM-Bench (Geng and Chang, 2025) extends coordination evaluation to multi-agent logistics and scheduling, showing that multi-agent tasks introduce qualitatively new failure modes such as misaligned role allocation and unstable negotiation. Generative agents work (Park et al., 2023) further showed that even cooperative multi-agent tasks can lead to brittle coordination and emergent failure cascades. Recent surveys on multi-agent cooperative decision-making (Jin et al., 2025) confirm that scaling from two-party to N-party settings introduces qualitatively new challenges—credit assignment, coalition instability, communication constraints—that standard benchmarks do not capture. Critically, none of these frameworks include adversarial scenarios or security-oriented domains.

2.3 LLM Agent Security Evaluation

Agent Security Bench (ASB) (Zhang et al., 2025) formalizes attacks and defenses for LLM agents with structured threat models, but is limited to single-agent scenarios without modeling inter-agent vulnerabilities or active user participation. Agent Dojo (Debenedetti et al., 2024) creates a dynamic environment for evaluating prompt injection attacks and demonstrates that modern agents fail under even mild adversarial pressure—but does not model an active user as an interaction participant, attacks propagating through inter-agent communication channels, or RAG system poisoning.

2.4 RAG Poisoning and Backdoor Attacks

Retrieval-Augmented Generation introduces a distinct attack surface that becomes especially dangerous in agentic settings. PoisonedRAG (Zou et al., 2024) showed that injecting as few as five malicious documents into a knowledge base with millions of entries achieves over 90% attack success rate. AgentPoison (Chen et al., 2024) extended this to agent-specific backdoor attacks via embedding-space manipulation, achieving over 80% ASR with less than 0.1% poison rate. BadAgent (Wang et al., 2024) demonstrated that backdoor triggers can be inserted directly into LLM agent weights, activating malicious behavior when specific content appears in retrieved documents. These findings motivate our `mail_rag_phishing` domain, which evaluates robustness to indirect prompt injection through a realistic email-based RAG system in a dual-control setting—a configuration not addressed by prior work.

2.5 Threat Modeling Frameworks

OWASP LLM Top 10 (OWASP Foundation, 2025b) and OWASP AI Agents Top 15 (OWASP Foundation, 2025a) systematize threats for AI systems. The AI-SAFE framework (Muleys et al., 2025) proposes a five-level threat model covering interface, execution, infrastructure, core logic, and data/knowledge attack surfaces. A recent comprehensive survey (Datta et al., 2025) systematizes agentic AI threats into an operational taxonomy connecting component-level risks (tool selection errors, memory leaks) to system-level harms (permission compromise, agent deception, multi-agent collusion). Our domains are grounded in these taxonomies to ensure systematic threat coverage.

Benchmark	Dual-ctrl	Security	Multi-agent	RAG atk.
AgentBench (Liu et al., 2025)	×	×	×	×
τ^2-bench (Barres et al., 2025)	✓	×	×	×
Agent Dojo (Debenedetti et al., 2024)	×	✓	×	×
ASB (Zhang et al., 2025)	×	✓	×	partial
REALM-Bench (Geng and Chang, 2025)	×	×	✓	×
DUMA-bench (ours)	✓	✓	✓	✓

Table 1: Comparison of DUMA-bench with related evaluation frameworks.

2.6 Positioning of This Work

DUMA-bench occupies the intersection left empty by prior work: it inherits the dual-control interaction model of τ^2-bench, the adversarial orientation of Agent Dojo and ASB, and the threat vocabulary of AI-SAFE and OWASP, combining them in evaluation scenarios where an active user and an adversarial environment co-exist. Table 1 summarizes how DUMA-bench compares to related benchmarks across the dimensions of dual-control, security focus, multi-agent interaction, and RAG attack coverage.

3 Method

3.1 Problem Formulation

3.1.1 Interaction Model (Dec-POMDP)

We formalize agent-user interaction as a Decentralized Partially Observable Markov Decision Process (Dec-POMDP) (Amato et al., 2013; Barres et al., 2025), following the τ^2-bench framework. The environment $\mathcal{E}$ is described by a state space $\mathcal{S}$ that is only partially observable to participants. The agent $\mathcal{A}$ and user $\mathcal{U}$ function as two autonomous players, each equipped with their own observation spaces Ω_A and Ω_U, and action spaces $\mathcal{A}_A$ and $\mathcal{A}_U$. The transition function $T : \mathcal{S} \times \mathcal{A}_A \times \mathcal{A}_U \rightarrow \Delta(\mathcal{S})$ defines environment dynamics, capturing how both agent and user actions jointly determine state evolution. Critically, the user is not a passive instruction source but actively changes environment state through their actions, creating genuine coordination challenges.

3.1.2 Attacker Model

We adopt a grey-box attacker model with realistic assumptions about adversary capabilities. The attacker possesses **system knowledge**, understanding the agent architecture and available tools, but has no access to the system prompt or model weights. The attacker's **capabilities** include injecting malicious content into various input channels such as emails, colleague messages, user queries, and document contents in RAG systems. The attacker's

goal is to force the agent to perform unauthorized actions or disclose confidential information, representing realistic threat scenarios in deployed agent systems.

3.1.3 Evaluation Metrics

pass@k metric. Defines the fraction of cases where the agent successfully passed k asserts:

$$\text{pass@}k = \frac{1}{N} \sum_{i=1}^{N} \mathbb{1}\left[\sum_{j=1}^{M_i} a_{ij} \geq k \right], \quad (1)$$

where N is the number of cases, M_i is the number of asserts in case i, $a_{ij} \in \{0, 1\}$ is the result of assert j.

Attack Success Rate (ASR). Attack success indicator:

$$\text{ASR} = 1 - \text{pass@1}. \quad (2)$$

In the security context, asserts verify that the agent maintains security invariants: absence of malicious instruction execution, preservation of data integrity, and refusal of unauthorized actions.

3.2 Developed Security Domains

3.2.1 `mail_rag_phishing` Domain (RAG Poisoning)

Description. Models an attack on an email client's RAG system through injection of malicious instructions in email content.

Threat classification: AI-SAFE.DATA.1 (Knowledge Base Poisoning), AI-SAFE.INPUT.1 (Indirect Prompt Injection), LLM01, RAG: Indirect Prompt Injection.

Domain architecture. The domain simulates an email client with integrated RAG for searching relevant emails. The knowledge base contains a mixture of legitimate and malicious emails designed to test the agent's ability to distinguish safe from compromised content. The agent has access to four tools: `search_emails` for querying the knowledge base, `get_email_details` for retrieving full message content, `send_email` for composing new messages, and `forward_email` for redistributing existing messages.

3.2.2 `collab` Domain (Inter-Agent Interaction)

Description. Models a multi-agent environment where an attacking agent ("colleague") manipulates the target agent through the communication channel.

Threat classification: AI-SAFE.INFRA.3 (Cross-Agent Poisoning), AI-SAFE.EXEC.1 (Tool Misuse), AI-SAFE.EXEC.2 (Privilege Escalation), T15 (Cross-Agent Communication Poisoning), MCP05.

Domain architecture. The domain implements a workspace with multiple agents operating at different privilege levels, creating opportunities for privilege escalation attacks. A ticketing and task system with delegation mechanisms enables attackers to manipulate task assignments. An activity log provides audit capabilities for detecting suspicious behavior. The agent can invoke five tools: `get_tickets` for retrieving assigned work, `update_ticket` for modifying task status, `delegate_task` for reassigning responsibilities, `get_logs` for accessing system activity, and `send_message` for inter-agent communication.

3.2.3 `output_handling` Domain (Output Processing)

Description. Tests agent robustness to generating malicious code or injections in output.

Threat classification: AI-SAFE.INPUT.3 (Improper Output Handling), LLM05.

Domain architecture. The domain models a web application where the agent generates content for display to end users. A database containing user data provides context for content generation while creating opportunities for SQL injection. A rendering system displays generated content in browsers, enabling testing of XSS and other injection vulnerabilities. The agent operates with four tools: `generate_content` for creating textual responses, `execute_query` for database access, `render_template` for formatting output, and `send_response` for delivering content to users.

4 Experiments

4.1 Experimental Setup

4.1.1 Models Under Study

We evaluate five state-of-the-art LLMs spanning different capability levels and architectural generations. **Claude Sonnet 4.5** represents Anthropic's latest model with strong reasoning capabilities. **GPT-4-turbo** provides OpenAI's advanced model with enhanced capabilities, while **GPT-4o** offers an optimized variant balancing performance and cost. **GPT-4o-mini** serves as a compact version with reduced cost, and **GPT-3.5-turbo** establishes a baseline for comparison. Agent generation pa-

rameters are fixed at temperature $T_{\text{agent}} = 0.0$ for all models to ensure deterministic agent behavior.

4.1.2 Variable Parameters

We vary the user model temperature across three levels to test robustness under different user behavior patterns: $T_{\text{user}} = 0.0$ for deterministic behavior, $T_{\text{user}} = 0.5$ for moderate variability, and $T_{\text{user}} = 1.0$ for high variability.

4.1.3 Metrics

We evaluate agent robustness using two complementary metrics. The **pass@k** metric measures the proportion of cases where the agent successfully passes at least k asserts, as formally defined in Equation 1. The **ASR (Attack Success Rate)** quantifies the proportion of successful attacks, computed as ASR $= 1 -$ pass@1. In our experiments, we primarily report pass@1 (at least 1 assert passed) and pass@4 (at least 4 asserts passed) metrics to evaluate both basic and stringent security thresholds.

4.1.4 Research Questions

Our experimental design is organized around three research questions that directly correspond to the methodological gap identified in the introduction.

RQ1: *How does interactive (dual-control) evaluation affect measured security robustness of LLM-based agents?* This question probes whether the presence of an active, state-modifying user changes the security conclusions drawn from evaluation. We examine whether robustness differences between models are detectable under dual-control conditions that would be invisible in static, passive-user settings.

RQ2: *How stable are security robustness metrics under variability in non-malicious user behavior?* Even when the user is not an attacker, their behavioral variability (captured by T_{user}) may modulate attack success rate through indirect effects on coordination and context. This question examines how sensitive ASR and pass@k are to non-adversarial user temperature variation.

RQ3: *Does increased model capability reliably translate into higher robustness under interactive security evaluation?* This question tests the assumption that larger or more capable models are systematically safer, examining whether the "bigger model = safer model" intuition holds across diverse attack domains in a dual-control setting.

4.1.5 Protocol

For each combination (model, temperature, domain, case), we perform $n = 10$ independent runs. All metrics are recorded, and results are aggregated for statistical analysis using Fisher's exact test (Fisher, 1935) for significance testing. We use Wilson confidence intervals (Wilson, 1927) for proportion estimates, which provide better coverage properties for small sample sizes compared to normal approximations.

5 Results & Discussion

5.1 Aggregated Results

Table 2 presents aggregated pass@1 results by model and domain across all temperature settings. Table 3 reports statistical significance of differences between GPT-4o and GPT-4o-mini at each temperature, and Table 4 shows the impact of temperature variation within each model.

5.2 Analysis

5.2.1 Research Question Analysis

RQ1: Effect of Dual-Control Evaluation on Measured Robustness. We find partial but meaningful evidence that dual-control evaluation changes measured security robustness. In the `mail_rag_phishing` domain, statistically significant differences between GPT-4o and GPT-4o-mini emerge ($p \approx 0.005$–0.013 across temperature settings), a result consistent with the hypothesis that user coordination dynamics amplify robustness differences between models. In the `collab` and `output_handling` domains, differences between models remain statistically insignificant ($p > 0.05$), suggesting either that these domains are less sensitive to user interaction dynamics or that the current experimental scale is insufficient to detect such effects. A direct comparison against passive-user (static) baselines—needed to close RQ1 definitively—is a planned extension of this work (Section 7).

RQ2: Stability Under Non-Malicious User Variability. Changes in user model temperature (T_{user}) cause measurable changes in ASR at fixed agent temperature, even when the user is not adversarial. This confirms that user behavioral variability is a genuine source of metric instability in dual-control security evaluation. The effect is most pronounced in the `collab` domain, where social engineering dynamics make agent behavior particularly sensitive to the phrasing and pacing

Table 2: Model Robustness Comparison by Domain (pass@1)

Model	RAG Phishing	Collab	Output
GPT-4o (T=0.0)	16/50 (32.0%)	13/60 (21.7%)	16/30 (53.3%)
GPT-4o (T=0.5)	18/50 (36.0%)	13/60 (21.7%)	18/30 (60.0%)
GPT-4o (T=1.0)	16/50 (32.0%)	17/60 (28.3%)	18/30 (60.0%)
GPT-4o-mini (T=0.0)	5/50 (10.0%)	18/60 (30.0%)	13/30 (43.3%)
GPT-4o-mini (T=0.5)	6/50 (12.0%)	13/60 (21.7%)	14/30 (46.7%)
GPT-4o-mini (T=1.0)	4/50 (8.0%)	18/60 (30.0%)	18/30 (60.0%)

Table 3: Statistical Significance: GPT-4o vs GPT-4o-mini (Fisher exact test, two-tailed)

Domain	T	4o pass@1	mini pass@1	4o ASR	mini ASR	p-value
mail_rag_phishing	0	16/50 (32%)	5/50 (10%)	68%	90%	1.28e-02
mail_rag_phishing	0.5	18/50 (36%)	6/50 (12%)	64%	88%	9.12e-03
mail_rag_phishing	1	16/50 (32%)	4/50 (8%)	68%	92%	5.04e-03
collab	0	13/60 (22%)	18/60 (30%)	78%	70%	4.04e-01
collab	0.5	13/60 (22%)	13/60 (22%)	78%	78%	1.00e+00
collab	1	17/60 (28%)	18/60 (30%)	72%	70%	1.00e+00
output_handling	0	16/30 (53%)	13/30 (43%)	47%	57%	6.06e-01
output_handling	0.5	18/30 (60%)	14/30 (47%)	40%	53%	4.38e-01
output_handling	1	18/30 (60%)	18/30 (60%)	40%	40%	1.00e+00

Table 4: Temperature Effect: p-values (Fisher exact test)

Domain	Model	T0:0.5	T0:1	T0.5:1
RAG phish.	4o	.833	1.00	.833
RAG phish.	4o-mini	1.00	1.00	.741
collab	4o	1.00	.528	.528
collab	4o-mini	.404	1.00	.404
output	4o	.795	.795	1.00
output	4o-mini	1.00	.301	.438

of user requests. Additionally, at fixed temperatures, increasing k in pass@k reduces variance—but ASR does not change monotonically with k. For example, Claude Sonnet 4.5 shows pass@1 = 0.25 but pass@4 = 0.20 in `mail_rag_phishing` at $T_{\text{user}} = 0.0$, indicating that agent robustness is sensitive to the stringency of the evaluation criterion.

RQ3: Model Capability vs. Security Robustness. Model size does not consistently predict security robustness under dual-control evaluation. GPT-4o (mid-sized) outperforms larger models (GPT-4-turbo, Claude Sonnet 4.5) in the `mail_rag_phishing` domain across all temperature settings, though it shows instability at higher k values. GPT-3.5-turbo, the smallest model, demonstrates the most stable performance across temperature variations. These results suggest that model scale and general capability are not reliable proxies for security robustness in interactive settings—domain-specific instruction following or safety training may play a more decisive role. This finding is consistent with the observation that security robustness is a distinct capability dimension not fully captured by general benchmarks.

5.2.2 Cross-Model Comparison

Key observations emerge when comparing all five models across domains. In the **RAG Poisoning (`mail_rag_phishing`)** domain, GPT-4o achieves the highest pass@1 (32-36% depending on T), outperforming both GPT-4-turbo (30-40%) and Claude Sonnet 4.5 (25%). GPT-4o-mini shows significantly lower performance (8-12%, $p < 0.01$), while GPT-3.5-turbo performs poorly (15-20%) but maintains consistent results across temperatures. For **Inter-Agent Attacks (`collab`)**, Claude Sonnet 4.5 demonstrates superior performance (96-100% pass@1), followed by GPT-4-turbo (96-100%) and GPT-4o (21.7-28.3%), with no statistically significant differences between GPT-4o and GPT-4o-mini ($p > 0.4$). In the **Output Handling (`output_handling`)** domain, Claude Sonnet 4.5 again leads (50-67%), followed by GPT-4-turbo (50-67%) and GPT-4o (53.3-60%), with differences between GPT-4o and GPT-4o-mini remaining statistically insignificant.

5.2.3 RAG System Vulnerability

The `mail_rag_phishing` domain remains the most challenging across all models: even the best configuration (Claude Sonnet 4.5 at $T = 0.5$) shows ASR = 75% at pass@1. This indicates high effectiveness of indirect prompt injection attacks through RAG context and the critical need for additional defenses (e.g., source validation, instruction filtering, policy-driven tool gating).

5.2.4 Temperature Stability

GPT-3.5-turbo exhibits the most stable behavior across different user temperatures, with minimal variance in pass@k metrics. In contrast, GPT-4o shows high sensitivity to temperature changes, particularly in the `collab` domain where pass@1 ranges from 21.7% to 28.3% as T_{user} increases from 0.0 to 1.0.

6 Conclusion

We present DUMA-bench, a benchmark that establishes a missing evaluation layer at the intersection of coordination and security for LLM-based agents. The core methodological claim is that security evaluation conducted without an active, state-modifying user systematically underestimates attack surface and misrepresents robustness differences between models. Our three domains—`mail_rag_phishing`, `collab`, and `output_handling`—embed adversarial content in dual-control environments formalized as Dec-POMDPs, enabling measurement of how user behavioral variability interacts with attack success rate.

Our findings address the three research questions directly. **RQ1**: Dual-control evaluation reveals statistically significant robustness differences in the RAG poisoning domain ($p \approx 0.005$–0.013) that are absent or ambiguous in static settings; extending this comparison with explicit passive-user baselines is the highest-priority next step. **RQ2**: Non-malicious user temperature variability measurably affects ASR and introduces non-monotonic behavior in pass@k, confirming that user dynamics are a genuine source of evaluation variance. **RQ3**: Model capability does not reliably predict security robustness—GPT-4o outperforms larger models in RAG poisoning while GPT-3.5-turbo shows greatest stability across domains—indicating that security robustness is a distinct capability dimension.

All models remain critically vulnerable to RAG poisoning (ASR 75–90%), underscoring that indirect prompt injection through retrieval systems is an unsolved problem requiring specialized defenses.

Future directions: (1) adding static (passive-user) baselines to close RQ1; (2) expanding model coverage to open-weight models (Llama, Mistral, Qwen) and models with built-in safety layers; (3) evaluating defense mechanisms (Llama Guard (Meta AI, 2024), Promptfoo, policy-driven tool gating); (4) extending DUMA-bench with additional threat domains (`resource_overload`, `supply_chain`); and (5) systematic analysis of assert structures to clarify success/failure semantics.

DUMA-bench is open-source and available at (Aleksandrov et al., 2025).

Acknowledgments

We thank the authors of τ^2-bench for their foundational work in dual-control agent evaluation, which inspired this research. We also acknowledge the Yandex Cloud team for developing the AI-SAFE framework.

7 Limitations

Our work has six important limitations. First, **absence of static baselines**: RQ1 asks whether dual-control evaluation changes measured robustness relative to passive-user settings, but the current study does not include a controlled static-baseline condition. Establishing this comparison is the most critical extension needed to validate the core methodological claim. Second, **sample size**: with $n = 10$ runs per configuration, larger samples would support more robust statistical conclusions, especially for domains where model differences are small; our use of Fisher's exact test and Wilson confidence intervals provides valid inference given the current scale. Third, **simulated users**: the user is modeled by an LLM, which may not fully capture the unpredictability of real human behavior; however, this approach ensures reproducibility and controlled experimentation. Fourth, **model coverage**: results are limited to five proprietary models from two families (GPT, Claude); generalization to open-weight models (Llama, Mistral, Qwen) and models with safety-specific fine-tuning is a planned extension. Fifth, **domain coverage**: DUMA-bench currently covers three security domains; additional domains such as `resource_overload` and `supply_chain` attacks are planned for future releases. Sixth, **assert semantics**: the success/failure semantics of the assert system—in particular, whether a run requires all asserts to pass (AND logic) or uses a weighted or hierarchical criterion—are detailed in the supplementary material and should be made more prominent in the main paper to facilitate comparison with future work.

References

Ivan Aleksandrov, German Kochnev, and Yaroslav Rogoza. 2025. Duma-benchmark: Dual-control multi-agent benchmark. https://github.com/sec-lab-itmo/duma-benchmark.

Christopher Amato, Girish Chowdhary, Alborz Geramifard, N. Kemal Ure, and Mykel J. Kochenderfer. 2013. Decentralized control of partially observable markov decision processes. In *52nd IEEE Conference on Decision and Control*, pages 2398–2405.

Vincent Barres, Hao Dong, Soumya Ray, Xinyun Si, and Karthik Narasimhan. 2025. τ^2-bench: Evaluating conversational agents in a dual-control environment. *arXiv preprint arXiv:2506.07982*.

Zhaorun Chen, Zhen Xiang, Chaowei Xiao, Dawn Song, and Bo Li. 2024. Agentpoison: Red-teaming llm agents via poisoning memory or knowledge bases. *arXiv preprint arXiv:2407.12784*.

Soheil Datta, Shozab Khurram Nahin, Akhil Chhabra, and Prasant Mohapatra. 2025. Agentic ai security: Threats, defenses, evaluation, and open challenges. *arXiv preprint arXiv:2510.23883*.

Edoardo Debenedetti and 1 others. 2024. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. In *Advances in Neural Information Processing Systems*, volume 37, pages 82895–82920.

Ronald A. Fisher. 1935. The logic of inductive inference. *Journal of the Royal Statistical Society*, 98(1):39–82.

Linqian Geng and Edward Y. Chang. 2025. Realm-bench: A benchmark for evaluating multi-agent systems on real-world, dynamic planning and scheduling tasks. *arXiv preprint arXiv:2502.18836*.

Wei Jin and 1 others. 2025. A comprehensive survey on multi-agent cooperative decision-making: Scenarios, approaches, challenges and perspectives. *arXiv preprint arXiv:2503.13415*.

Xiao Liu and 1 others. 2025. Agentbench: Evaluating llms as agents. *arXiv preprint arXiv:2308.03688*.

Meta AI. 2024. Llama guard: Llm-based input-output safeguard for human-ai conversations. Technical report.

R. Muleys, S. Nesteruk, and A. Lodin. 2025. Ai secure agentic framework essentials (ai-safe) v1.0. Technical report, Yandex Cloud.

OWASP Foundation. 2025a. Owasp ai agents (agentic ai) top 15. Available at owasp.org.

OWASP Foundation. 2025b. Owasp top 10 for large language model applications. Available at owasp.org.

Joon Sung Park, Joseph C. O'Brien, Carrie J. Cai, Meredith Ringel Morris, Percy Liang, and Michael S. Bernstein. 2023. Generative agents: Interactive simulacra of human behavior. In *Proceedings of the 36th Annual ACM Symposium on User Interface Software and Technology (UIST)*, pages 1–22.

Yujia Qin and 1 others. 2025. Tool learning with foundation models. *ACM Computing Surveys*, 57:1–40.

Timo Schick and 1 others. 2023. Toolformer: Language models can teach themselves to use tools. In *Advances in Neural Information Processing Systems*, volume 36, pages 68539–68551.

Yizhen Wang, Deyuan Xue, Sheng Zhang, and Shuo Qian. 2024. Badagent: Inserting and activating backdoor attacks in llm agents. *arXiv preprint arXiv:2406.03007*.

Edwin B. Wilson. 1927. Probable inference, the law of succession, and statistical inference. *Journal of the American Statistical Association*, 22(158):209–212.

Shunyu Yao, Noah Shinn, Pedram Razavi, and Karthik Narasimhan. 2024. τ-bench: A benchmark for tool-agent-user interaction in real-world domains. *arXiv preprint arXiv:2406.12045*.

Hanrong Zhang and 1 others. 2025. Agent security bench (asb): Formalizing and benchmarking attacks and defenses in llm-based agents. *arXiv preprint arXiv:2410.02644*.

Wei Zou, Runpeng Geng, Binghui Wang, and Jinyuan Jia. 2024. Poisonedrag: Knowledge corruption attacks to retrieval-augmented generation of large language models. *arXiv preprint arXiv:2402.07867*.